

Индивидуальный проект. Этап 4

Артём Дмитриевич Петлин

2026-05-02

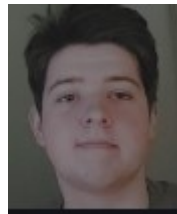
Содержание I

- 1 Информация
- 2 Цель работы
- 3 Задание
- 4 Теоретическое введение
- 5 Выполнение лабораторной работы
- 6 Выводы

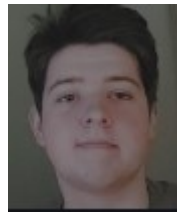
Раздел 1

Информация

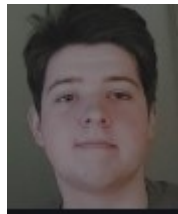
- Петлин Артём Дмитриевич



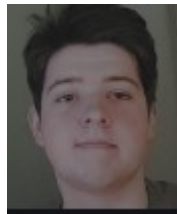
- Петлин Артём Дмитриевич
- студент



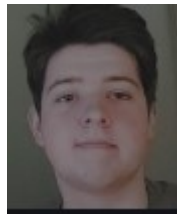
- Петлин Артём Дмитриевич
- студент
- группа НПИбд-02-24



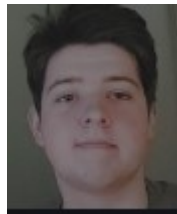
- Петлин Артём Дмитриевич
- студент
- группа НПИбд-02-24
- Российский университет дружбы народов



- Петлин Артём Дмитриевич
- студент
- группа НПИбд-02-24
- Российский университет дружбы народов
- 1132246846@pfur.ru



- Петлин Артём Дмитриевич
- студент
- группа НПИбд-02-24
- Российский университет дружбы народов
- 1132246846@pfur.ru
- https://github.com/hikrim/study_2025-2026_infosec-intro



Раздел 2

Цель работы

Цель работы

Проведение автоматизированного сканирования веб-сервера на наличие известных уязвимостей, ошибок конфигурации и потенциально опасных файлов.

Раздел 3

Задание

- Найти максимальное количество уязвимостей различных типов.

- Найти максимальное количество уязвимостей различных типов.
- Реализовать успешную эксплуатацию каждой уязвимости.

Раздел 4

Теоретическое введение

- Ищутся уязвимости в специально предназначенном для этого веб приложении под названием Damn Vulnerable Web Application (DVWA).

- Ищутся уязвимости в специально предназначенном для этого веб приложении под названием Damn Vulnerable Web Application (DVWA).
- Назначение DVWA — попрактиковаться в некоторых самых распространённых веб уязвимостях.

- Ищутся уязвимости в специально предназначенном для этого веб приложении под названием Damn Vulnerable Web Application (DVWA).
- Назначение DVWA — попрактиковаться в некоторых самых распространённых веб уязвимостях.
- Предлагается попробовать и обнаружить так много уязвимостей, как сможете.

Раздел 5

Выполнение лабораторной работы

Nikto показывает:

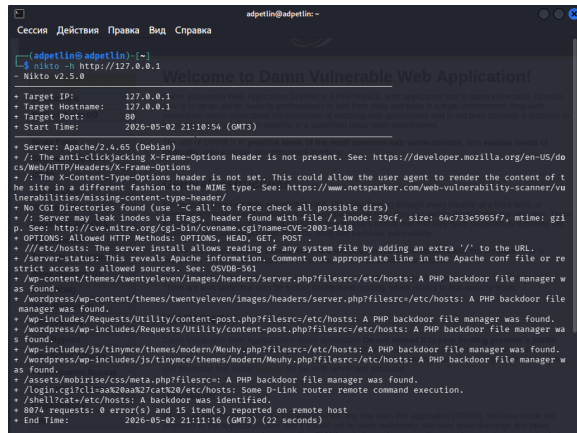
1 Информация о сервере

```
adpetlin@adpetlin: ~  
$ nikto -h http://127.0.0.1  
- Nikto v2.5.0  
  
+ Target IP: 127.0.0.1  
+ Target Hostname: 127.0.0.1  
+ Target Port: 80  
+ Start Time: 2026-05-02 21:10:54 (GMT3)  
  
+ Server: Apache/2.4.65 (Debian)  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ No CGI Directories found (use '-C all' to force check all possible dirs)  
+ /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 64c733e5965f7, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST .  
+ /etc/passwd: The server install allows reading of any system file by adding an extra '/' to the URL.  
+ /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict access to allowed sources. See: OSVDB-561  
+ /wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wp-includes/Requests/Utility/content-post.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /assets/mobirise/css/meta.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /login.cgi?cli-aaX20aaX27catX20/etc/passwd: Some D-Link router remote command execution.  
+ /shell?cat+etc/passwd: A backdoor was identified.  
+ 8074 requests: 0 error(s) and 15 item(s) reported on remote host  
+ End Time: 2026-05-02 21:11:16 (GMT3) (22 seconds)
```

Рисунок 1: http://127.0.0.1

Nikto показывает:

- 1 Информация о сервере
- 2 Отсутствующие заголовки безопасности, такие как X-Frame-Options, X-Content-Type-Options.

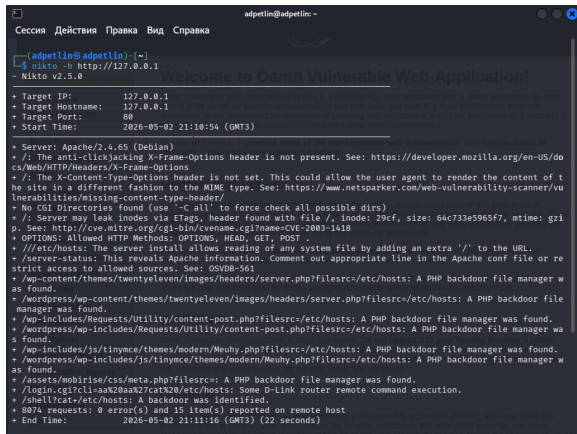


```
adpetlin@adpetlin: ~  
Сессия Действия Правка Вид Справка  
(adpetlin@adpetlin)-[~]  
$ nikto -h http://127.0.0.1  
- Nikto v2.5.0  
  
+ Target IP: 127.0.0.1  
+ Target Hostname: 127.0.0.1  
+ Target Port: 80  
+ Start Time: 2026-05-02 21:10:54 (GMT3)  
  
+ Server: Apache/2.4.65 (Debian)  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ No CGI Directories found (use '-c all' to force check all possible dirs)  
+ /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 64c733e5965f7, mtime: gzipp. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST .  
+ /etc/passwd: The server install allows reading of any system file by adding an extra '/' to the URL.  
+ /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict access to allowed sources. See: OSVDB-561  
+ /wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wp-includes/Requests/Utility/content-post.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /assets/mobirise/css/meta.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /login.cgi?cli-aaX20aaX27catX20/etc/passwd: Some D-Link router remote command execution.  
+ /shell?cat+etc/passwd: A backdoor was identified.  
+ 8074 requests: 0 error(s) and 15 item(s) reported on remote host  
+ End Time: 2026-05-02 21:11:16 (GMT3) (22 seconds)
```

Рисунок 1: <http://127.0.0.1>

Nikto показывает:

- 1 Информация о сервере
- 2 Отсутствующие заголовки безопасности, такие как X-Frame-Options, X-Content-Type-Options.
- 3 /server-status — раскрыта информация о статусе Apache (OSVDB-561)

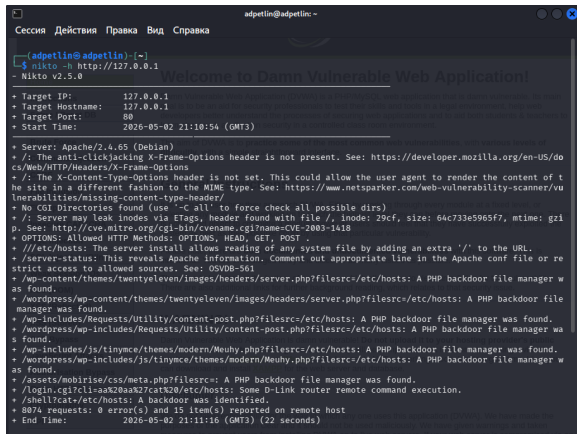


```
adpetlin@adpetlin: ~  
Сессия Действия Правка Вид Справка  
(adpetlin@adpetlin)-[~]  
$ nikto -h http://127.0.0.1  
- Nikto v2.5.0  
  
+ Target IP: 127.0.0.1  
+ Target Hostname: 127.0.0.1  
+ Target Port: 80  
+ Start Time: 2026-05-02 21:10:54 (GMT3)  
  
+ Server: Apache/2.4.65 (Debian)  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ No CGI Directories found (use "-C all" to force check all possible dirs)  
+ /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 64c733e5965f7, mtime: gzipp. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST .  
+ /etc/passwd: The server install allows reading of any system file by adding an extra '/' to the URL.  
+ /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict access to allowed sources. See: OSVDB-561  
+ /wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wp-includes/Requests/Utility/content-post.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /assets/mobirise/css/meta.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /login.cgi?cli-aaX20aaX27catX20/etc/passwd: Some D-Link router remote command execution.  
+ /shell?cat+etc/passwd: A backdoor was identified.  
+ 8074 requests: 0 error(s) and 15 item(s) reported on remote host  
+ End Time: 2026-05-02 21:11:16 (GMT3) (22 seconds)
```

Рисунок 1: <http://127.0.0.1>

Nikto показывает:

- 1 Информация о сервере
- 2 Отсутствующие заголовки безопасности, такие как X-Frame-Options, X-Content-Type-Options.
- 3 /server-status — раскрыта информация о статусе Apache (OSVDB-561)
- 4 /etc/hosts — возможна читка системных файлов через добавление „/“

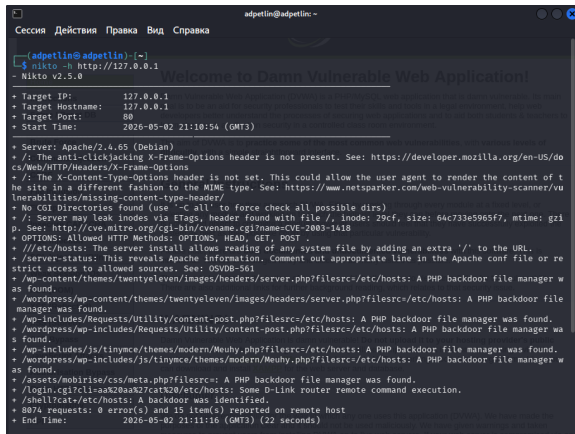


```
adpetlin@adpetlin: ~  
$ nikto -h http://127.0.0.1  
- Nikto v2.5.0  
  
+ Target IP: 127.0.0.1  
+ Target Hostname: 127.0.0.1  
+ Target Port: 80  
+ Start Time: 2026-05-02 21:10:54 (GMT3)  
  
+ Server: Apache/2.4.65 (Debian)  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ No CGI Directories found (use "-c all" to force check all possible dirs)  
+ /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 64c733e5965f7, mtime: gzipp. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST.  
+ /etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.  
+ /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict access to allowed sources. See: OSVDB-561  
+ /wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /assets/mobirise/css/meta.php?filesrc=: A PHP backdoor file manager was found.  
+ /login.cgi?cli-aaX20aaX27catX20/etc/hosts: Some D-Link router remote command execution.  
+ /shell?cat=/etc/hosts: A backdoor was identified.  
+ 8074 requests: 0 error(s) and 15 item(s) reported on remote host  
+ End Time: 2026-05-02 21:11:16 (GMT3) (22 seconds)
```

Рисунок 1: http://127.0.0.1

Nikto показывает:

- 1 Информация о сервере
- 2 Отсутствующие заголовки безопасности, такие как X-Frame-Options, X-Content-Type-Options.
- 3 /server-status — раскрыта информация о статусе Apache (OSVDB-561)
- 4 /etc/hosts — возможна читка системных файлов через добавление „/“
- 5 Найдены PHP backdoor файлы в директориях WordPress

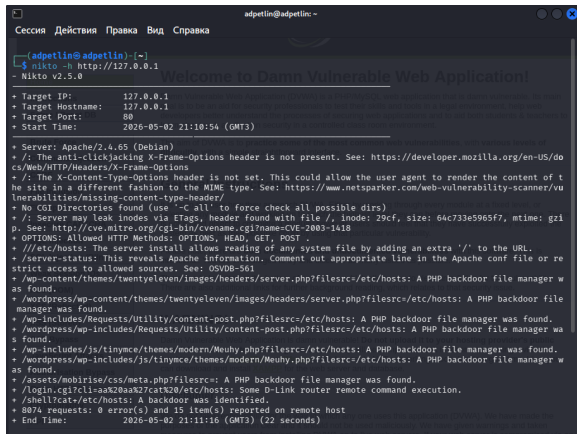


```
adpetlin@adpetlin: ~  
Сессия Действия Правка Вид Справка  
(adpetlin@adpetlin)-[~]  
$ nikto -h http://127.0.0.1  
- Nikto v2.5.0  
  
Welcome to Damn Vulnerable Web Application!  
  
+ Target IP: 127.0.0.1  
+ Target Hostname: 127.0.0.1  
+ Target Port: 80  
+ Start Time: 2026-05-02 21:10:54 (GMT3)  
  
+ Server: Apache/2.4.65 (Debian)  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ No CGI Directories found (use "-C all" to force check all possible dirs)  
+ /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 64c733e5965f7, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST.  
+ /etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.  
+ /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict access to allowed sources. See: OSVDB-561  
+ /wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /assets/mobirise/css/meta.php?filesrc=: A PHP backdoor file manager was found.  
+ /login.cgi?cli-aaK20aaK27catK20/etc/hosts: Some D-Link router remote command execution.  
+ /shell?cat=/etc/hosts: A backdoor was identified.  
+ 8074 requests: 0 error(s) and 15 item(s) reported on remote host  
+ End Time: 2026-05-02 21:11:16 (GMT3) (22 seconds)
```

Рисунок 1: http://127.0.0.1

Nikto показывает:

- 1 Информация о сервере
- 2 Отсутствующие заголовки безопасности, такие как X-Frame-Options, X-Content-Type-Options.
- 3 /server-status — раскрыта информация о статусе Apache (OSVDB-561)
- 4 /etc/hosts — возможна читка системных файлов через добавление „/“
- 5 Найдены PHP backdoor файлы в директориях WordPress
- 6 /shell?cat+/etc/hosts — идентифицирован бэкдор



```
adpetlin@adpetlin: ~  
Сессия Действия Правка Вид Справка  
(adpetlin@adpetlin)-[~]  
$ nikto -h http://127.0.0.1  
- Nikto v2.5.0  
  
Welcome to Damn Vulnerable Web Application!  
  
+ Target IP: 127.0.0.1  
+ Target Hostname: 127.0.0.1  
+ Target Port: 80  
+ Start Time: 2026-05-02 21:10:54 (GMT3)  
  
+ Server: Apache/2.4.65 (Debian)  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ No CGI Directories found (use "-C all" to force check all possible dirs)  
+ /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 64c733e5965f7, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST.  
+ //etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.  
+ /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict access to allowed sources. See: OSVDB-561  
+ /wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /assets/mobirise/css/meta.php?filesrc=: A PHP backdoor file manager was found.  
+ /login.cgi?cli=aaK20aaK27catK20/etc/hosts: Some D-Link router remote command execution.  
+ /shell?cat+/etc/hosts: A backdoor was identified.  
+ 8074 requests: 0 error(s) and 15 item(s) reported on remote host  
+ End Time: 2026-05-02 21:11:16 (GMT3) (22 seconds)
```

Рисунок 1: http://127.0.0.1

Nikto показывает:

- 1 Информация о сервере
- 2 Отсутствующие заголовки безопасности, такие как X-Frame-Options, X-Content-Type-Options.
- 3 /server-status — раскрыта информация о статусе Apache (OSVDB-561)
- 4 /etc/hosts — возможна читка системных файлов через добавление „/“
- 5 Найдены PHP backdoor файлы в директориях WordPress
- 6 /shell?cat+/etc/hosts — идентифицирован бэкдор
- 7 /login.cgi — уязвимость D-Link router (CVE-2003-1418)

```
adpetlin@adpetlin: ~  
$ nikto -h http://127.0.0.1  
- Nikto v2.5.0  
  
+ Target IP: 127.0.0.1  
+ Target Hostname: 127.0.0.1  
+ Target Port: 80  
+ Start Time: 2026-05-02 21:10:54 (GMT3)  
  
+ Server: Apache/2.4.65 (Debian)  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ No CGI Directories found (use "-C all" to force check all possible dirs)  
+ /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 64c733e5965f7, mtime: gzipp. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST.  
+ /etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.  
+ /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict access to allowed sources. See: OSVDB-561  
+ /wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /assets/mobirise/css/meta.php?filesrc=: A PHP backdoor file manager was found.  
+ /login.cgi?cli=aaK20aaK27catK20/etc/hosts: Some D-Link router remote command execution.  
+ /shell?cat+/etc/hosts: A backdoor was identified.  
+ 8074 requests: 0 error(s) and 15 item(s) reported on remote host  
+ End Time: 2026-05-02 21:11:16 (GMT3) (22 seconds)
```

Рисунок 1: http://127.0.0.1

Сканирование DVWA приложения:

- 1 /DVWA/config/ — найдена директория конфигурации

```
(adpetlin@adpetlin)-[~]
$ nikto -h http://127.0.0.1/DVWA
- Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Start Time: 2026-05-02 21:12:53 (GMT3)

+ Server: Apache/2.4.65 (Debian)
+ /DVWA/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /DVWA/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Root page /DVWA redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST .
+ /DVWA///etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.
+ /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ /DVWA/tests/: Directory indexing found.
+ /DVWA/tests/: This might be interesting.
+ /DVWA/database/: Directory indexing found.
+ /DVWA/database/: Database directory found.
+ /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ /DVWA/.git/index: Git Index file may contain directory listing information.
+ /DVWA/.git/HEAD: Git HEAD file found. Full repo details may be present.
+ /DVWA/.git/config: Git config file found. Infos about repo details may be present.
+ /DVWA/.gitignore: .gitignore file found. It is possible to grasp the directory structure.
+ /DVWA/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/assets/mobirise/css/meta.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/login.cgi?cli=aaK20aaX27cat%20/etc/hosts: Some D-Link router remote command execution.
+ /DVWA/shell?cat=/etc/hosts: A backdoor was identified.
+ /DVWA/.dockerignore: .dockerignore file found. It may be possible to grasp the directory structure and learn more about the site.
+ B074 requests: 0 error(s) and 26 item(s) reported on remote host
+ End Time: 2026-05-02 21:13:14 (GMT3) (21 seconds)
```

Сканирование DVWA приложения:

- 1 /DVWA/config/ — найдена директория конфигурации
- 2 /DVWA/tests/ — тестовые файлы доступны

```
(adpetlin@adpetlin)-[~]
$ nikto -h http://127.0.0.1/DVWA
- Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Start Time: 2026-05-02 21:12:53 (GMT3)

+ Server: Apache/2.4.65 (Debian)
+ /DVWA/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /DVWA/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Root page /DVWA redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST .
+ /DVWA///etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.
+ /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ /DVWA/tests/: Directory indexing found.
+ /DVWA/tests/: This might be interesting.
+ /DVWA/database/: Directory indexing found.
+ /DVWA/database/: Database directory found.
+ /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ /DVWA/.git/index: Git Index file may contain directory listing information.
+ /DVWA/.git/HEAD: Git HEAD file found. Full repo details may be present.
+ /DVWA/.git/config: Git config file found. Infos about repo details may be present.
+ /DVWA/.gitignore: .gitignore file found. It is possible to grasp the directory structure.
+ /DVWA/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/assets/mobirise/css/meta.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/login.cgi?cli=aaK20aaX27catK20/etc/hosts: Some D-Link router remote command execution.
+ /DVWA/shell?cat=/etc/hosts: A backdoor was identified.
+ /DVWA/.dockerignore: .dockerignore file found. It may be possible to grasp the directory structure and learn more about the site.
+ B074 requests: 0 error(s) and 26 item(s) reported on remote host
+ End Time: 2026-05-02 21:13:14 (GMT3) (21 seconds)
```

Сканирование DVWA приложения:

- 1 /DVWA/config/ — найдена директория конфигурации
- 2 /DVWA/tests/ — тестовые файлы доступны
- 3 /DVWA/database/ — директория БД открыта

```
(adpetlin@adpetlin)-[~]
$ nikto -h http://127.0.0.1/DVWA
- Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Start Time: 2026-05-02 21:12:53 (GMT3)

+ Server: Apache/2.4.65 (Debian)
+ /DVWA/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /DVWA/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Root page /DVWA redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST .
+ /DVWA///etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.
+ /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ /DVWA/tests/: Directory indexing found.
+ /DVWA/tests/: This might be interesting.
+ /DVWA/database/: Directory indexing found.
+ /DVWA/database/: Database directory found.
+ /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ /DVWA/.git/index: Git Index file may contain directory listing information.
+ /DVWA/.git/HEAD: Git HEAD file found. Full repo details may be present.
+ /DVWA/.git/config: Git config file found. Infos about repo details may be present.
+ /DVWA/.gitignore: .gitignore file found. It is possible to grasp the directory structure.
+ /DVWA/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/assets/mobirise/css/meta.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/login.cgi?cli=aaK20aaX27cat%20/etc/hosts: Some D-Link router remote command execution.
+ /DVWA/shell?cat=/etc/hosts: A backdoor was identified.
+ /DVWA/.dockerignore: .dockerignore file found. It may be possible to grasp the directory structure and learn more about the site.
+ B074 requests: 0 error(s) and 26 item(s) reported on remote host
+ End Time: 2026-05-02 21:13:14 (GMT3) (21 seconds)
```

Сканирование DVWA приложения:

- 1 /DVWA/config/ — найдена директория конфигурации
- 2 /DVWA/tests/ — тестовые файлы доступны
- 3 /DVWA/database/ — директория БД открыта
- 4 /DVWA/docs/ — документация доступна

```
(adpetlin@adpetlin)-[~]
$ nikto -h http://127.0.0.1/DVWA
- Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Start Time: 2026-05-02 21:12:53 (GMT3)

+ Server: Apache/2.4.65 (Debian)
+ /DVWA/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /DVWA/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Root page /DVWA redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST .
+ /DVWA///etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.
+ /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ /DVWA/tests/: Directory indexing found.
+ /DVWA/tests/: This might be interesting.
+ /DVWA/database/: Directory indexing found.
+ /DVWA/database/: Database directory found.
+ /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ /DVWA/.git/index: Git Index file may contain directory listing information.
+ /DVWA/.git/HEAD: Git HEAD file found. Full repo details may be present.
+ /DVWA/.git/config: Git config file found. Infos about repo details may be present.
+ /DVWA/.gitignore: .gitignore file found. It is possible to grasp the directory structure.
+ /DVWA/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wp-includes/js/tinyMCE/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-includes/js/tinyMCE/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/assets/mobirise/css/meta.php?filesrc=: A PHP backdoor file manager was found.
+ /DVWA/login.cgi?cli=aaX20aaX27catX20/etc/hosts: Some D-Link router remote command execution.
+ /DVWA/shell?cat=/etc/hosts: A backdoor was identified.
+ /DVWA/.dockerignore: .dockerignore file found. It may be possible to grasp the directory structure and learn more about the site.
+ B074 requests: 0 error(s) and 26 item(s) reported on remote host
+ End Time: 2026-05-02 21:13:14 (GMT3) (21 seconds)
```

- 5 .git/index — возможно получение полной истории репозитория

- 5 .git/index — возможно получение полной истории репозитория
- 6 .git/config — информация о настройках Git

- 5 .git/index — возможно получение полной истории репозитория
- 6 .git/config — информация о настройках Git
- 7 .gitignore — раскрыта структура директорий

- 5 .git/index — возможно получение полной истории репозитория
- 6 .git/config — информация о настройках Git
- 7 .gitignore — раскрыта структура директорий
- 8 .dockerignore — информация о Docker-конфигурации

- 5 .git/index — возможно получение полной истории репозитория
- 6 .git/config — информация о настройках Git
- 7 .gitignore — раскрыта структура директорий
- 8 .dockerignore — информация о Docker-конфигурации
- 9 Те же backdoor файлы что и в первом сканировании

- 5 .git/index — возможно получение полной истории репозитория
- 6 .git/config — информация о настройках Git
- 7 .gitignore — раскрыта структура директорий
- 8 .dockerignore — информация о Docker-конфигурации
- 9 Те же backdoor файлы что и в первом сканировании
- 10 /DVWA/login.php — страница администратора найдена

Раздел 6

Выводы

Мы провели автоматизированное сканирование веб-сервера на наличие известных уязвимостей, ошибок конфигурации и потенциально опасных файлов.

Раздел 7

Список литературы

- 1 Парасрам, Ш. Kali Linux: Тестирование на проникновение и безопасность : Для профессионалов. Kali Linux / Ш. Парасрам, А. Замм, Т. Хериянто, и др. – Санкт-Петербург : Питер, 2022. – 448 сс.